

PROJET DE SÉCURISATION DU SYSTÈME D'INFORMATION D'UNE PME

Candidature au Titre Expert en Cybersécurité – Niveau 7

Candidat : Jérémie ESTIVAL

Année universitaire : 2025 – 2026

Sujet du projet :

Conception et déploiement d'une stratégie globale de cybersécurité pour une PME multisite de 150 collaborateurs

Résumé exécutif

La cybersécurité constitue aujourd'hui un enjeu majeur pour les organisations, quelles que soient leur taille ou leur activité. Les cyberattaques ciblant les PME sont en constante augmentation et exploitent principalement des vulnérabilités techniques, organisationnelles et humaines.

Le présent projet vise à concevoir et mettre en œuvre une stratégie complète de sécurisation du système d'information d'une PME fictive de 150 collaborateurs nommée Quantisys.

L'objectif consiste à améliorer significativement la posture de sécurité de l'entreprise en intervenant sur plusieurs axes :

- Gouvernance de la sécurité ;
- Gestion des identités et des accès ;
- Surveillance continue du SI ;
- Gestion des vulnérabilités ;
- Sensibilisation des utilisateurs ;
- Audit et amélioration continue ;
- Gestion de projet cybersécurité.

Le projet s'appuie sur plusieurs solutions reconnues du marché telles que Wazuh, Suricata, OpenVAS et Microsoft Entra ID afin de construire une architecture moderne reposant sur les principes du Zero Trust et de la défense en profondeur.

À l'issue du projet, l'entreprise bénéficie d'une réduction significative de son exposition aux risques cyber, d'une meilleure capacité de détection des incidents et d'un niveau de maturité supérieur en matière de gouvernance de la sécurité.

1. Présentation de l'entreprise

1.1 Présentation générale

Quantisys France est une entreprise spécialisée dans le développement de logiciels métier à destination des professionnels du secteur bancaire et assurantiel.

L'entreprise emploie 150 collaborateurs répartis sur trois sites :

- Paris (siège social)
- Lyon
- Toulouse

L'activité repose fortement sur les technologies numériques et implique la manipulation quotidienne de données sensibles appartenant à ses clients.

L'entreprise dispose également d'une politique de télétravail permettant à plus de 60 % des collaborateurs

d'accéder aux ressources internes à distance.

1.2 Organisation informatique

Le département informatique est composé de :

Fonction	Effectif
Responsable informatique	1
Administrateurs systèmes	2
Administrateurs réseau	1
Support informatique	3
Développeurs	20

À ce jour, aucun RSSI n'est officiellement nommé.

La cybersécurité est assurée de manière ponctuelle par l'équipe informatique.

Cette situation représente un risque important compte tenu de la croissance rapide de l'entreprise.

1.3 Infrastructure technique

L'infrastructure est constituée de :

Réseau :

- 3 sites interconnectés via VPN IPSec
- 4 VLAN utilisateurs
- 1 VLAN serveurs
- 1 VLAN administration

Serveurs :

- 10 serveurs Windows Server 2022
- 2 serveurs Linux Ubuntu
- 1 Active Directory principal
- 1 Active Directory secondaire

Cloud :

- Microsoft 365
- SharePoint Online
- Exchange Online
- Teams

Postes de travail :

- 150 postes Windows 11
- 20 ordinateurs portables

2. Contexte et problématique

2.1 Évolution de la menace

Selon l'ANSSI, les PME sont devenues des cibles privilégiées des cybercriminels.

Les principales menaces observées sont :

- Rançongiciels
- Phishing

- Vol d'identifiants
- Attaques sur les accès distants
- Exploitation de vulnérabilités non corrigées

Les conséquences potentielles incluent :

- Arrêt d'activité
- Perte financière
- Atteinte à l'image de marque
- Sanctions réglementaires

2.2 Constat initial

L'audit préliminaire réalisé sur l'environnement de Quantisys a permis d'identifier plusieurs faiblesses.

Gouvernance

- Absence de politique de sécurité formalisée
- Absence de référentiel documentaire
- Processus de changement non documenté

Gestion des accès

- MFA déployé uniquement pour certains administrateurs
- Comptes inactifs présents dans l'Active Directory
- Contrôles d'accès insuffisants

Supervision

- Absence de SIEM
- Journaux dispersés
- Aucun mécanisme de corrélation

Gestion des vulnérabilités

- Aucun scan périodique
- Absence d'inventaire des vulnérabilités
- Correctifs déployés de manière réactive

Sensibilisation

- Aucune campagne de sensibilisation
- Aucun exercice de phishing

2.3 Problématique

Comment mettre en œuvre une stratégie globale de cybersécurité permettant d'améliorer durablement la protection du système d'information de Quantisys tout en garantissant la continuité de l'activité et la conformité aux bonnes pratiques de sécurité ?

3. Analyse des risques

3.1 Méthodologie

L'analyse de risques est réalisée selon les principes de la méthode EBIOS Risk Manager.

Cette approche permet :

- d'identifier les actifs critiques ;
- d'évaluer les menaces ;
- d'estimer les impacts ;
- de prioriser les mesures de sécurité.

Actif	Importance
Active Directory	Critique
Messagerie Microsoft 365	Critique
Données clients	Critique
Infrastructure VPN	Élevée
Serveurs applicatifs	Élevée
Postes utilisateurs	Moyenne

3.3 Cartographie des menaces

Menace	Probabilité	Impact
Phishing	Élevée	Élevé
Ransomware	Moyenne	Critique
Compromission VPN	Moyenne	Critique
Fuite de données	Moyenne	Critique
Escalade de privilèges	Élevée	Élevé
Erreur humaine	Élevée	Élevé

3.4 Matrice de criticité

Risque	Criticité
Ransomware	Critique
Compromission AD	Critique
Vol de données	Critique
Phishing	Élevée
Mauvaise configuration	Élevée

Risque	Criticité
Perte de disponibilité	Élevée

. Architecture de sécurité cible

4.1 Objectifs de l'architecture

L'architecture proposée doit répondre aux objectifs suivants :

- Réduire la surface d'attaque.
- Limiter la propagation d'une compromission.
- Renforcer la visibilité sur les événements de sécurité.
- Améliorer la résilience du système d'information.
- Garantir la traçabilité des actions utilisateurs et administrateurs.

L'approche retenue repose sur le principe de la défense en profondeur et du Zero Trust.

4.2 Principes de sécurité appliqués

Défense en profondeur

Plusieurs couches de sécurité sont déployées :

- Pare-feu
- Segmentation réseau
- IDS/IPS
- MFA
- SIEM
- Gestion des vulnérabilités
- Sensibilisation utilisateur

Ainsi, une défaillance d'un mécanisme n'entraîne pas automatiquement la compromission du système.

Zero Trust

Le modèle Zero Trust repose sur le principe : "Never Trust, Always Verify"

Chaque utilisateur, équipement ou application doit être authentifié et autorisé avant d'accéder à une ressource.

4.3 Architecture logique

L'architecture est organisée en plusieurs zones de sécurité.

Zone Internet

Cette zone représente les utilisateurs externes ainsi que les partenaires.

Elle constitue la principale source de menaces.

Zone DMZ

Cette zone héberge :

- Reverse Proxy
- Serveur Web
- Serveur VPN

Les équipements exposés à Internet sont isolés du réseau interne.

Zone Serveurs

Cette zone héberge :

- Active Directory
- Serveurs de fichiers
- Applications métier
- Bases de données

Seuls les flux strictement nécessaires sont autorisés.

Zone Utilisateurs

Cette zone regroupe :

- Postes de travail
- Ordinateurs portables
- Téléphones professionnels

Zone Administration

Cette zone contient :

- Bastion d'administration
- Outils de supervision
- Consoles de sécurité

L'accès est réservé aux administrateurs habilités.

4.4 Segmentation réseau

La segmentation repose sur plusieurs VLAN.

VLAN	Description
------	-------------

VLAN 10	Utilisateurs
---------	--------------

VLAN 20	Serveurs
---------	----------

VLAN 30	Administration
---------	----------------

VLAN 40	DMZ
---------	-----

VLAN 50	Supervision
---------	-------------

Chaque flux est filtré par le pare-feu.

Cette approche permet de limiter les mouvements latéraux en cas de compromission.

(Voir annexe « Architecture réseau »)

5. Gestion des identités et des accès

5.1 Contexte

L'analyse initiale a mis en évidence plusieurs problèmes :

- Comptes inactifs non supprimés.
- MFA partiellement déployé.
- Comptes administrateurs trop nombreux.
- Contrôle des privilèges insuffisant.

5.2 Politique IAM

Une politique IAM (Identity and Access Management) est mise en œuvre.

Les objectifs sont :

- Contrôler les accès.
- Réduire les privilèges excessifs.
- Améliorer la traçabilité.
- Réduire les risques de compromission.

5.3 Principe du moindre privilège

Chaque utilisateur reçoit uniquement les droits nécessaires à ses missions.

Exemple :

Profil	Accès
Comptable	ERP uniquement
Développeur	Dépôts Git
RH	Données RH
Administrateur	Ressources techniques

5.4 Authentification multifacteur (MFA)

Le MFA devient obligatoire pour :

- Administrateurs.
- Comptes privilégiés.
- VPN.
- Microsoft 365.

Facteurs retenus :

- Mot de passe.
- Application Microsoft Authenticator.

Cette mesure réduit fortement le risque lié au vol d'identifiants.

5.5 Gestion du cycle de vie des comptes

Le cycle de vie suit les étapes suivantes :

Arrivée

- Création du compte.
- Attribution des droits.

Mobilité

- Révision des autorisations.
- Mise à jour des groupes.

Départ

- Désactivation immédiate.
- Archivage.
- Suppression après 90 jours.

5.6 Contrôle périodique

Tous les trimestres :

- Vérification des comptes actifs.
- Vérification des comptes administrateurs.
- Contrôle des privilèges.

Les résultats sont documentés dans un rapport de conformité.

6. Surveillance et détection

6.1 Objectifs

La surveillance continue vise à :

- Détecter rapidement les incidents.
- Réduire le temps de réaction.
- Fournir des preuves d'investigation.
- Répondre aux exigences d'audit.

6.2 Mise en place d'un SIEM

La solution retenue est : Wazuh

Wazuh est une plateforme open source permettant :

- Collecte de logs.
- Corrélation d'événements.
- Détection d'intrusion.
- Gestion de conformité.
- Analyse de vulnérabilités.

6.3 Sources de journaux collectées

Active Directory

- Connexions.
- Créations de comptes.
- Modifications de groupes.

Serveurs Windows

- Événements système.
- Services.
- Élévations de privilèges.

Serveurs Linux

- Authentifications SSH.
- Commandes administrateur.
- Événements système.

Pare-feu

- Connexions entrantes.
- Flux bloqués.
- Tentatives suspectes.

VPN

- Connexions utilisateurs.
- Échecs d'authentification.

6.4 Paramètres critiques surveillés

Paramètre	Importance
Échecs de connexion	Élevée
Création d'un compte admin	Critique
Désactivation antivirus	Critique
Connexion hors horaires	Élevée
Exécution PowerShell	Élevée
Tentative brute force	Critique

6.5 Mise en place d'un IDS

La solution retenue est : Suricata

Suricata surveille :

- Le trafic réseau.
- Les tentatives d'exploitation.
- Les scans de ports.
- Les communications malveillantes.

6.6 Exemple de scénario détecté

Cas : attaque par brute force

Étape 1 :

Un attaquant tente plusieurs connexions VPN.

Étape 2 :

Le pare-feu génère des journaux.

Étape 3 :

Wazuh reçoit les événements.

Étape 4 :

Une règle de corrélation détecte plus de 10 échecs en 5 minutes.

Étape 5 :

Une alerte critique est créée.

Étape 6 :

Le compte est automatiquement bloqué.

6.7 Indicateurs de sécurité

Les indicateurs suivants sont suivis :

KPI	Objectif
Temps moyen de détection	< 15 min
Vulnérabilités critiques ouvertes	< 5
MFA déployé	100 %
Taux de collecte logs	> 95 %
Disponibilité SIEM	> 99 %

6.8 Politique de conservation des logs

Les journaux sont conservés :

Type	Durée
Journaux système	12 mois
Journaux sécurité	12 mois
Journaux VPN	12 mois
Journaux pare-feu	12 mois

Les données sont stockées sur un serveur dédié sécurisé.

7. Gestion des vulnérabilités

7.1 Objectifs

La gestion des vulnérabilités vise à :

- Identifier les failles de sécurité.
- Évaluer leur niveau de criticité.
- Prioriser les actions correctives.
- Réduire la surface d'attaque.
- Maintenir un niveau de sécurité acceptable.

Cette démarche s'inscrit dans un processus continu d'amélioration de la sécurité.

7.2 Outil retenu

OpenVAS (Greenbone Vulnerability Manager)

OpenVAS permet :

- L'analyse automatisée des systèmes.
- La détection de vulnérabilités connues.
- L'évaluation des risques.
- La génération de rapports détaillés.

L'outil est déployé sur un serveur dédié au sein du VLAN Supervision.

7.3 Périmètre des scans

Les analyses concernent :

Serveurs Windows

- Active Directory
- Serveurs de fichiers
- Serveurs métiers

Serveurs Linux

- Applications web
- Reverse Proxy
- Services internes

Équipements réseau

- Pare-feu
- Switches administrables
- Routeurs VPN

Postes utilisateurs

- Échantillon représentatif de 30 postes

7.4 Résultats des analyses

Vulnérabilités critiques

Vulnérabilité	CVSS	Risque
Compte admin sans MFA	9.8	Critique
Apache obsolète	8.1	Critique
SMB Signing désactivé	7.5	Élevé
TLS 1.0 activé	6.8	Moyen

Vulnérabilités moyennes

Vulnérabilité	CVSS
Logiciels non mis à jour	5.2
Configuration faible navigateur	4.8
Certificats proches expiration	4.2

7.5 Plan de remédiation

Les vulnérabilités sont traitées selon leur criticité.

Niveau	Délai
Critique	48 h
Haute	7 jours
Moyenne	30 jours
Faible	90 jours

7.6 Cycle de gestion

Le processus adopté est :

Identification

↓

Qualification

↓

Priorisation

↓

Correction

↓

Validation

↓

Nouvelle analyse

8. Plan de remédiation

8.1 Mesures techniques

Renforcement Active Directory

Actions :

- Suppression des comptes obsolètes.

- Mise en œuvre MFA.
- Réduction des privilèges administrateurs.
- Désactivation protocoles obsolètes.

Renforcement des serveurs

Mesures :

- Mise à jour complète.
- Durcissement des configurations.
- Désactivation des services inutiles.
- Journalisation avancée.

Renforcement du réseau

Mesures :

- Filtrage des flux.
- Segmentation VLAN.
- Restriction des accès administratifs.
- Surveillance du trafic.

8.2 Tableau de suivi

Action	Responsable	Statut
Déploiement MFA	Admin Système	Terminé
Déploiement Wazuh	RSSI	Terminé
Mise à jour serveurs	Admin Système	En cours
Sensibilisation utilisateurs	RH	Planifié

9. Gestion des changements

9.1 Objectifs

Garantir que chaque modification du système :

- soit documentée ;
- soit validée ;
- soit testée ;
- ne dégrade pas la sécurité.

9.2 Processus de changement

Étape 1 : Demande

Le demandeur soumet :

- description ;
- justification ;
- impacts attendus.

Étape 2 : Analyse

Évaluation :

- sécurité ;
- disponibilité ;
- conformité ;
- coûts.

Étape 3 : Validation

Validation par :

- Responsable informatique
- RSSI

Étape 4 : Préproduction

Tests réalisés dans un environnement isolé.

Étape 5 : Déploiement

Mise en production selon une fenêtre planifiée.

Étape 6 : Contrôle

Vérification :

- fonctionnement ;
- sécurité ;
- absence de régression.

10. Sensibilisation à la cybersécurité

10.1 Objectifs

La majorité des incidents de sécurité impliquent une erreur humaine.

Le programme vise à :

- réduire les comportements à risque ;
- développer une culture sécurité ;
- améliorer la détection des attaques.

10.2 Public concerné

L'ensemble des collaborateurs :

- Direction
- RH
- Comptabilité
- Développeurs

- Administrateurs

10.3 Programme annuel

Trimestre 1

Introduction à la cybersécurité.

Trimestre 2

Phishing et ingénierie sociale.

Trimestre 3

Télétravail sécurisé.

Trimestre 4

Protection des données.

10.4 Simulation de phishing

Une campagne est organisée tous les six mois.

Objectifs :

- mesurer la vigilance ;
- identifier les populations à risque ;
- adapter les formations.

10.5 Indicateurs

KPI	Objectif
Participation	> 90 %
Réussite quiz	> 80 %
Clic phishing	< 5 %

11. Audit de sécurité

11.1 Référentiel retenu

L'audit est basé sur :

- ISO 27001

- Guides ANSSI
- Bonnes pratiques CIS Controls

11.2 Objectifs

Vérifier :

- l'efficacité des mesures ;
- le respect des procédures ;
- la conformité globale.

11.3 Domaines audités

Gouvernance

- politique sécurité ;
- rôles et responsabilités.

Gestion des accès

- MFA ;
- privilèges.

Supervision

- SIEM ;
- alertes.

Vulnérabilités

- scans ;
- correctifs.

Sensibilisation

- participation ;
- efficacité.

11.4 Résultats de l'audit

Points forts

- Architecture segmentée.
- MFA généralisé.
- SIEM opérationnel.
- Gestion des vulnérabilités structurée.

Points faibles

- Documentation encore incomplète.
- Dépendance forte à certains administrateurs.
- Processus de reprise d'activité à renforcer.

11.5 Recommandations

Court terme

- Compléter les procédures.
- Renforcer PRA/PCA.

Moyen terme

- Déployer EDR.
- Réaliser exercices de crise.

Long terme

- Certification ISO 27001.
- Création d'un SOC interne.

12. Gestion du projet cybersécurité

12.1 Organisation du projet

Afin d'assurer la réussite du projet, une gouvernance adaptée est mise en place.

Comité de pilotage

Le comité de pilotage est composé :

- Directeur Général
- Responsable Informatique
- RSSI
- Représentant des métiers

Le comité se réunit mensuellement afin de :

- suivre l'avancement ;
- arbitrer les décisions ;
- gérer les risques ;
- valider les livrables.

12.2 Équipe projet

Fonction	Rôle
Chef de projet cybersécurité	Pilotage global
RSSI	Validation sécurité
Administrateur système	Déploiement technique
Administrateur réseau	Architecture réseau
Support informatique	Accompagnement utilisateurs
RH	Sensibilisation

12.3 Méthodologie

Le projet est piloté selon une approche hybride :

- Cycle en V pour l'architecture.
- Approche agile pour les déploiements.

Cette méthode permet :

- une meilleure maîtrise des risques ;
- une adaptation rapide aux contraintes ;
- une validation progressive des livrables.

13. Planning prévisionnel

13.1 Découpage du projet

Phase 1 : Analyse

Durée : 2 semaines

Livrables :

- Cartographie SI
- Analyse des risques
- Cahier des charges

Phase 2 : Conception

Durée : 2 semaines

Livrables :

- Architecture cible
- Politique IAM
- Politique de supervision

Phase 3 : Déploiement

Durée : 4 semaines

Livrables :

- Wazuh
- Suricata
- MFA
- VLAN

Phase 4 : Tests

Durée : 2 semaines

Livrables :

- Rapport de tests
- Validation sécurité

Phase 5 : Audit

Durée : 1 semaine

Livrables :

- Rapport d'audit
- Plan d'amélioration

Phase 6 : Clôture

Durée : 1 semaine

Livrables :

- Documentation finale
- Retour d'expérience

13.2 Diagramme de Gantt simplifié

S1 S2 S3 S4 S5 S6 S7 S8 S9 S10 S11 S12



(Voir annexe « Diagramme de Gantt » dans GitHub)

4. Matrice RACI

14.1 Répartition des responsabilités

Activité	Chef projet	RSSI	Admin Sys	Admin Réseau	Direction
Analyse risques	A	R	C	C	I
Architecture	A	R	C	R	I
Déploiement MFA	I	A	R	C	I
Déploiement SIEM	A	R	R	C	I
Audit	C	R	C	C	A
Validation finale	I	C	I	I	A

Légende :

- R = Responsable
- A = Autorité
- C = Consulté
- I = Informé

15. Budget prévisionnel

15.1 Ressources humaines

Ressource	Coût estimé
Chef projet	12 000 €
RSSI	8 000 €
Administrateurs	10 000 €
Sous-total : 30 000 €	

15.2 Ressources techniques

Solution	Coût
Wazuh	0 €
Suricata	0 €
OpenVAS	0 €
Serveur supervision	3 500 €
Formation sécurité	5 000 €
Sous-total : 8 500 €	

15.3 Budget global

Budget estimé : 38 500 €

Ce budget demeure raisonnable pour une PME de 150 collaborateurs.

16. Campagne de tests

16.1 Objectifs

A valider :

- le bon fonctionnement des mécanismes de sécurité ;
- la détection des attaques ;
- la conformité des configurations.

16.2 Tests réalisés

Test MFA

Résultat : Succès

Tous les comptes administrateurs utilisent désormais une authentification forte.

Test de détection

Simulation :

- brute force VPN ;
- scan réseau Nmap ;
- tentative d'escalade de privilège.

Résultat :

Détection par Wazuh et Suricata.

Test de vulnérabilité

Analyse OpenVAS après remédiation.

Résultat :

- Vulnérabilités critiques : 0
- Vulnérabilités hautes : 2
- Vulnérabilités moyennes : 7

Test PRA

Simulation :

Panne serveur Active Directory.

Résultat : Reprise de service via contrôleur secondaire.

17. Indicateurs de performance

17.1 Avant projet

Indicateur	Valeur
MFA	20 %
Vulnérabilités critiques	14
Supervision SI	0 %
Sensibilisation	15 %

17.2 Après projet

Indicateur	Valeur
MFA	100 %
Vulnérabilités	0

Indicateur	Valeur
critiques	
Supervision SI	95 %
Sensibilisation	92 %

18. Retour sur investissement

18.1 Bénéfices obtenus

Techniques

- Réduction de la surface d'attaque.
- Visibilité accrue sur le SI.
- Détection rapide des incidents.

Organisationnels

- Formalisation des processus.
- Meilleure gouvernance.
- Sensibilisation des collaborateurs.

Financiers

- Réduction du risque d'interruption d'activité.
- Réduction des coûts liés aux incidents.

19. Perspectives d'évolution

Les évolutions envisagées sont :

Court terme

- Déploiement d'un EDR.
- Renforcement PRA/PCA.

Moyen terme

- Automatisation de la réponse aux incidents.
- Mise en place d'un SOC.

Long terme

- Certification ISO 27001.
- Mise en œuvre d'une démarche DevSecOps.